보안사고 신고 및 초기 대응 절차

문서번호	GW-SEC-072	시행일	2026.10.01
작성·관리	정보보안팀	문서판	1.0

1. 사고 인지와 최초 신고

1.1 신고 대상

계정 탈취 의심, 악성코드 감염, 업무기기 분실, 자료 오발송, 승인되지 않은 공개 링크, 고객정보의 부적절한 조회·유출 가능성을 발견하면 사고로 확정되지 않았더라도 신고한다.

1.2 직원 최초 행동

직원은 가능한 한 추가 전송·사용을 중지하고, 최초 발견 시각·영향받은 시스템·실제 확인 사실을 기록한다. 삭제·포맷·로그 정리·공개 게시 등 증거를 훼손하는 행동은 하지 않는다.

1.3 신고 경로

사내 포털 [보안센터 > 사고 신고]로 접수한다. 포털이 중단되면 사내 비상연락체계의 정보보안 담당 연락처로 먼저 보고하고 복구 후 사건번호로 기록한다.

2. 접수와 초동 조치

2.1 사실 확인

정보보안팀은 접수자, 사고 유형, 영향받은 자산, 확인된 정보 항목, 진행 중인 위험을 확인한다. 확인된 사실과 추정·미확인 내용을 구분하여 사고 타임라인을 작성한다.

2.2 격리·접근 제한

정보보안팀의 지휘 아래 IT지원팀이 계정 잠금, 세션 철회, 단말 격리, 공유 링크 중지 등 승인된 최소한의 조치를 수행한다. 조치 전후 시각과 영향 범위를 기록한다.

2.3 자료 보전

관련 로그와 증빙 파일은 별도의 접근 제한 공간에 저장하고 누가 언제 수집·전달했는지 이력을 남긴다. 개인 메신저나 일반 헬프데스크 첨부로 고객정보 원문을 무분별하게 전달하지 않는다.

2.4 관계부서 통지

개인정보 관련 사안은 개인정보 담당자에게 즉시 이관해 법정 통지·신고 대상과 기한을 판단하도록 한다. 법률상 해당하는 유출 통지는 시행령 기준과 예외를 검토하며, 내부 신고 접수와 대외 통지를 같은 절차로 보지 않는다.

3. 사고 분석과 종결

3.1 영향 평가

사고책임자는 피해 범위, 노출 경로, 재발 가능성, 계정·데이터 보호조치와 업무 복구 조건을 검토한다. 대외기관·정보주체 통지는 승인된 담당자와 법무 검토 절차를 거쳐 수행한다.

3.2 복구 판단

취약점 조치, 인증수단 재발급, 원상 복구와 모니터링을 분리해 검증한다. 서비스가 정상화되어도 개인정보 관련 후속 의무가 완료되었다고 단정하지 않는다.

3.3 사후 개선

원인 분석과 개선 과제에 담당자·기한을 부여하고 후속 검증 후 사건을 종결한다. 책임 추궁 여부와 관계없이 사고를 재현·확산하는 미승인 행위를 금지한다.

업무 처리 기준 및 확인 사항

표 1. 사고 처리 단계별 책임

단계	책임	필수 기록
발견·신고	직원 / 접수부서	발견시각·관찰 사실
분류·영향 평가	정보보안팀	사건번호·범위·미확인 내용
개인정보 판단	개인정보보호담당	통지·신고 요건 검토
기술 차단·복구	IT지원팀	승인자·조치시각·검증
종결·개선	사고책임자	원인·개선과제·재점검

별첨 / 서식

별첨 1. 보안사고 최초 신고서

발견자 / 소속		발견 시각(KST)	
사고 유형		영향 시스템·기기	
확인된 현상		정보 유출 의심 항목	
현재 진행 중 위험		임시 조치 여부	
증거 보관 위치		추가 담당자 / 사건 번호	

사실과 추정을 명확히 구분한다. 이 문서의 신고 완료가 법정 개인정보 유출 통지·신고를 대체하지 않는다.